

AI Vendor Risk & Internal Governance Integration

Part 1

Executive Risk Briefing

1.1 Business Case vs. Threat Landscape

The CISO's proposal to deploy Threat-LLM within our Security Operations Center carries real operational weight. Automating malware analysis, enriching threat intelligence feeds, and generating incident response playbooks are not novelties — they directly address the analyst fatigue and alert overload that cripple most modern SOC's. The potential upside is significant: faster triage cycles, more consistent documentation, and cognitive offloading of repetitive tasks to an always-available AI layer.

That said, the way this platform operates introduces risks that cannot be dismissed at the board level. Threat-LLM requires a continuous stream of firewall logs, endpoint telemetry, and live alert data to function at full capacity. That is not just sensitive operational data — it is a real-time picture of our internal attack surface handed to a third-party vendor.

Strategic Risks at a Glance

Risk Category	Potential Impact	Why It Matters
Data Privacy Violation	Regulatory fines (GDPR, NIS2)	Internal telemetry may carry PII — employee device IDs, browsing artifacts, or user-attributed events
IP Leakage via Training	Competitive / legal exposure	Without explicit opt-out clauses, vendor may use our alert patterns to train their LLM, effectively externalizing proprietary threat intel
Model Hallucination	Incident misclassification	AI-generated playbooks or malware analysis could be plausible-sounding but factually wrong, leading analysts down the wrong path
Vendor Lock-in	Operational dependency	If the platform becomes embedded in SOC workflows, exit becomes costly — especially if SLAs degrade or the vendor is acquired
Supply Chain Exposure	Lateral risk propagation	A compromise of the vendor's infrastructure could expose our telemetry stream — essentially a SolarWinds-style scenario targeting our SOC

1.2 Regulatory & Framework Mapping

To structure this risk analysis, I am using the NIST AI Risk Management Framework (AI RMF 1.0) as the primary lens, supplemented by ISO/IEC 42001:2023 for organizational AI governance. These frameworks were

selected because they address the full lifecycle of AI adoption — not just technical controls, but governance structures, transparency obligations, and accountability chains.

NIST AI RMF — Core Function Mapping

- **GOVERN:** The organization must establish clear ownership of AI risk. Deploying Threat-LLM without a dedicated AI Risk Owner or AI governance policy creates an accountability gap at the board level. ISO/IEC 42001 Clause 5.1 similarly requires top management to demonstrate commitment to the AI management system.
- **MAP:** The risk mapping function requires identifying all AI-specific risks before deployment. The vendor's data ingestion model — streaming live telemetry — falls squarely into high-risk territory under the AI RMF's risk tiering guidance, as errors in this context directly affect security decision-making.
- **MEASURE:** Quantifying hallucination rates, output confidence scoring, and bias assessment of Threat-LLM's models must be part of our vendor due diligence. Without baseline metrics, we have no way to measure whether the platform is performing as advertised.
- **MANAGE:** Risk responses must be defined before go-live. The governance constraints proposed in Section 1.3 below are the operational translation of this function.

ISO/IEC 42001:2023 Annex A (Controls A.6 and A.8) specifically addresses AI system impact assessments and data governance for third-party AI systems — both directly applicable to the Threat-LLM integration scenario.

1.3 Strategic Conditions for Approval

The following three governance constraints are proposed as non-negotiable requirements to be written into the vendor contract before any data streaming commences. These are not suggestions — they are the minimum threshold for a risk-acceptable deployment.

C-01	Data Retention Limit & Destruction Guarantee — The vendor contract must specify a maximum data retention window of 30 days for all ingested telemetry, with automated purge mechanisms and verifiable deletion certificates. Any retention beyond this window requires explicit written approval from our CISO and DPO. This directly addresses the risk of our operational data being stored indefinitely in vendor infrastructure.
C-02	Explicit Opt-Out from Model Training — A hard contractual prohibition must be placed on the use of any organizational data — including firewall logs, alert content, endpoint telemetry, or derived inferences — for the purpose of training, fine-tuning, or improving the vendor's LLM models. This clause must survive contract renewals and be binding on any successor entity in the event of acquisition.
C-03	AI Output Audit & Incident SLA — The vendor must provide a documented hallucination rate baseline for the malware analysis and playbook generation modules, along with a contractual SLA for output accuracy audits (minimum quarterly). In the event that AI-generated output contributes to a missed detection or incorrect incident response action, the vendor must participate in a joint post-incident review within 72 hours. This creates accountability without eliminating the vendor relationship.

Conclusion & Recommendation

Threat-LLM is a credible investment in SOC capability — but the current proposal as described is not yet ready for board approval. The operational benefits are real, but they are outweighed by unaddressed risks around data sovereignty, training data rights, and output reliability.

Conditional approval is recommended, contingent on full execution of the three contract clauses outlined above, a formal AI risk assessment under the NIST AI RMF GOVERN and MAP functions prior to go-live, and a 90-day pilot period with restricted data scope before full telemetry streaming is enabled.

Part 2

AI Acceptable Use Policy (AUP) — SOC Operations

2.1 Purpose and Scope

This Acceptable Use Policy governs the use of the Threat-LLM AI platform within the Security Operations Center. It applies to all SOC Tier 1, Tier 2, and Tier 3 analysts, security engineers, incident responders, and any contractor or third-party personnel granted access to the platform.

The purpose of this policy is not to restrict the usefulness of Threat-LLM — it is to make sure we use it without accidentally making our security posture worse. AI tools are powerful, but they can be wrong, they can leak data, and they can create false confidence. This policy exists so that every analyst knows exactly where the boundaries are before they start typing into a prompt.

When This Policy Applies

- Any use of the Threat-LLM prompt interface for analysis, triage, or documentation purposes
- Interactions with Threat-LLM-generated outputs, including malware analysis reports, threat intelligence summaries, and incident response playbooks
- API-level integrations between Threat-LLM and internal SIEM, EDR, or ticketing systems
- Use of the platform in both live production environments and non-production testing environments

This policy does NOT apply to internal AI tools developed and hosted within the organization's own infrastructure, which are governed by separate internal AI governance procedures.

2.2 Data Handling & Sanitization Rules

This is the most critical section of this policy. Before any data is entered into a Threat-LLM prompt, the analyst must verify that the content does not fall into any of the prohibited categories listed below. There is no exception process for these restrictions — if you are unsure whether data is safe to submit, the answer is: do not submit it.

Data Type	Examples / What This Includes	Status
Personally Identifiable Information (PII)	Employee names, usernames, email addresses, device IDs attributable to individuals, user-linked IP activity logs	PROHIBITED
Internal IP Addresses & Network Topology	RFC-1918 address ranges in use, VLAN configurations, subnet maps, routing tables, firewall zone names	PROHIBITED
Proprietary Source Code	Any internal scripts, detection rules (YARA/Sigma), custom SIEM logic, automation playbooks developed in-house	PROHIBITED
Raw Credentials or Secrets	API keys, passwords, tokens, hashes extracted from endpoints or logs, even if partially redacted	PROHIBITED
Full Packet Captures (PCAP)	Unfiltered packet data that may contain session payloads, authentication exchanges, or cleartext protocol data	PROHIBITED

Sanitized IOCs & Generic Malware Samples	SHA256 hashes, anonymized PCAP snippets with PII removed, CVE references, public threat intel	PERMITTED
Generic Incident Descriptions	Textual descriptions of alert patterns without internal identifiers or asset-specific details	PERMITTED

Sanitization Procedure (Before Any Submission)

1. Strip or replace all IP addresses with placeholder values (e.g., 10.x.x.x → [INTERNAL HOST])
2. Remove all usernames, employee identifiers, and device names from log snippets before pasting
3. Replace organization-specific asset names (server names, hostnames, product names) with generic labels
4. Do not copy-paste directly from live SIEM dashboards — always manually transcribe and sanitize first

2.3 Verification and Output Integrity

AI hallucination is not a theoretical risk — it is a documented behavior of large language models, including production-grade security AI platforms. Threat-LLM may produce malware analysis conclusions, attribution statements, or playbook steps that are internally consistent, professionally phrased, and factually wrong. The following verification steps are mandatory before any AI-generated output is acted upon in a live incident.

Mandatory Output Verification Checklist

STEP 1	Cross-reference with authoritative sources — Any threat attribution, CVE reference, malware family classification, or TTP mapping produced by Threat-LLM must be independently verified against at least one authoritative source (e.g., MITRE ATT&CK, VirusTotal, NIST NVD, or vendor advisories) before it is recorded in an incident ticket or communicated to stakeholders.
STEP 2	Escalate before acting on high-confidence outputs — Paradoxically, high-confidence AI outputs should trigger more scrutiny, not less. If Threat-LLM generates a playbook recommending an immediate containment action (e.g., isolating a host, blocking a subnet, or killing a process), a Tier 2 analyst or above must review and approve the action before execution. AI confidence scores are not a substitute for human authorization.
STEP 3	Flag and log anomalous outputs — Any AI output that appears inconsistent, contradicts known threat intel, or recommends an unusual remediation path must be flagged in the platform's feedback interface and logged in the SOC's anomaly register. This data feeds the quarterly vendor audit required under Contract Clause C-03.
STEP 4	No direct playbook execution without review — Incident response playbooks generated by Threat-LLM must be reviewed as a whole document before any step is executed. Analysts must not execute playbook steps sequentially without reading ahead — a hallucinated step mid-playbook can cause damage even if the earlier steps were correct.

Output Trust Levels

The following informal trust model is recommended for daily analyst use:

- Use directly with citation: Publicly available IOC lookups, CVE descriptions, MITRE ATT&CK technique references — verify against source, then cite both AI summary and original source.
- Use with verification: Malware behavior analysis, log pattern interpretation, threat actor attribution — must be cross-referenced before inclusion in an incident report.
- Do not use without senior analyst review: Containment recommendations, eradication steps, network isolation decisions — always requires human sign-off regardless of AI confidence level.

Policy Enforcement & Acknowledgment

All personnel within scope of this policy are required to read, understand, and sign an acknowledgment form before being granted access to the Threat-LLM platform. Violations of this policy — particularly the data submission restrictions in Section 2.2 — will be treated as a potential data security incident and reviewed under the organization's standard incident response procedures.

This policy will be reviewed and updated at minimum annually, or following any significant change to the Threat-LLM platform's capabilities, data handling practices, or the organization's regulatory obligations.

References

- National Institute of Standards and Technology (NIST). (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. <https://doi.org/10.6028/NIST.AI.100-1>
 - International Organization for Standardization. (2023). ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system. ISO.
 - MITRE Corporation. (2024). MITRE ATT&CK Enterprise Framework (v14). <https://attack.mitre.org>
 - European Parliament. (2024). EU Artificial Intelligence Act (Regulation (EU) 2024/1689). Official Journal of the European Union.
 - ENISA. (2023). AI Cybersecurity Challenges: Threat Landscape for Artificial Intelligence. European Union Agency for Cybersecurity.
-